

Security Incident Report

Report ID	CLD-IR-0002
Related ticket	CLD-0002 Reported phishing email impersonating Cloudora HR
Report title	Payroll Credential Phishing Campaign Resulting in Two Compromised Accounts
Analyst	Eshak Basta
Date of report (UTC)	2026-08-25
Incident severity	P1 Critical
Status	Contained, eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

On August 25, 2026, Cloudora was targeted by a payroll phishing campaign that impersonated the HR team and attempted to steal employee login credentials. The phishing emails were sent to 40 employees, with six employees clicking the link and two, Freya Lynn and Ryan Boyd, submitting their credentials. The attacker later used the stolen credentials to successfully access both accounts from Amsterdam. Once the compromise was confirmed, the affected accounts were secured, the malicious infrastructure was blocked, and the phishing emails were removed. No further attacker sign ins were found after containment, but continued monitoring was recommended.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 25, 06:58	Message Trace	Legitimate Cloudora newsletter delivered	The Mailchimp newsletter was investigated and confirmed legitimately. This was the cleared false positive.
Aug 25, 08:04 to 08:20	Message Trace	Phishing Variant A wave 1 sent to Cloudora employees	Sent from 198.18.44.10 while spoofing payroll@cloudora.io. SPF, DKIM, and DMARC failed. Some emails were delivered and others quarantined.
Aug 25, 08:35 to 08:50	Message Trace	Second phishing wave delivered	Variant A used 198.18.44.23. Variant B used 198.18.51.7 and the lookalike domain cloudora-hr-portal.example.
Aug 25, 08:39:03	Message Trace	Seth Lane clicked the phishing link	Link was clicked, but no credentials were submitted.

Aug 25, 08:47:12	Message Trace	Freya Lynn clicked the phishing link and submitted credentials	Freya's credentials were now considered compromised.
Aug 25, 09:05:44	Message Trace	Ryan Boyd clicked the phishing link and submitted credentials	Ryan submitted credentials to the Variant B phishing page.
Aug 25, 09:11	Ticket	Phishing incident reported to SOC	James Holt forwarded the phishing email. Ticket CLD-0002 was opened, and the investigation began.
Aug 25, 09:58, 10:12, 11:47	Message Trace	Three more employees clicked the phishing link	Hugo Marsh, Chloe Price, and Dina Said clicked but did not submit credentials.
Aug 25, 10:34:20	Sign In Logs	Attacker successfully signed into Freya Lynn's account	Sign in came from 198.18.7.200 in Amsterdam using Windows 11 and Chrome. Outlook Web was accessed around 10:36 and SharePoint around 10:41.
Aug 25, 13:22:05	Sign In Logs	Attacker successfully signed into Ryan Boyd's account	Same attacker IP 198.18.7.200 from Amsterdam. Outlook Web accessed at 13:25:33.
Aug 25, around 14:00	Incident Response	Containment started on both compromised accounts	Sessions and tokens were revoked, credentials were reset, MFA was re-registered, malicious infrastructure was blocked, and phishing emails were purged.
Aug 25, after containment	Sign In Logs	Containment was verified	Victims sign in and attacker IP queries were run again. No additional activity from 198.18.7.200 was found.

3. Findings

Finding 1: A payroll phishing campaign targeted Cloudora employees

On August 25, 2026, a payroll phishing campaign targeted 40 Cloudora employees. The emails impersonated Cloudora HR and directed employees to the fake domain `cloudora-hr-portal.example`. Message trace logs showed that 36 employees had at least one phishing email delivered, while four employees had all copies quarantined. This shows the phishing campaign reached a large number of Cloudora employees.

Finding 2: The attackers used two different phishing variants

Variant A spoofed the legitimate `payroll@cloudora.io` address and failed SPF, DKIM, and DMARC. It was sent from 198.18.44.10 and 198.18.44.23. Variant B came from the fake `cloudora-hr-portal.example` domain using 198.18.51.7 and passed SPF, DKIM, and DMARC for the fake domain. This shows that an email passing authentication does not automatically mean it is safe.

Finding 3: Freya Lynn's account was compromised

Freya Lynn clicked the phishing link and submitted her credentials at 08:47:12 UTC. At 10:34:20 UTC, her account was accessed from 198.18.7.200 in Amsterdam using Windows 11 and Chrome, which did not match her normal Manchester activity. The attacker then accessed Outlook Web and SharePoint. This confirms that Freya's stolen credentials were successfully used by the attacker

Finding 4: Ryan Boyd's account was also compromised

Ryan Boyd clicked the Variant B phishing link and submitted his credentials at 09:05:44 UTC. At 13:22:05 UTC, his account was accessed from the same attacker IP, 198.18.7.200, in Amsterdam using Windows 11 and Chrome. Outlook Web was then accessed at 13:25:33 UTC. This confirms Ryan was the second compromised account in the campaign

Finding 5: Four other employees clicked but did not submit credentials

Seth Lane, Hugo Marsh, Chloe Price, and Dina Said clicked the phishing link but did not submit credentials. No account compromise was confirmed for these users. This separates the higher risk compromised accounts from employees who interacted with the phishing campaign but did not give the attacker their passwords.

Finding 6: The reported Mailchimp newsletter was a false positive

The Cloudora Monthly newsletter was investigated because it was reported alongside the phishing emails. The email passed SPF, DKIM, and DMARC for the legitimate cloudora.io domain and was sent through Mailchimp, which Cloudora authorized to send email. The newsletter was confirmed legitimately and cleared as a false positive.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IP Address	198.18.44.10	Aug 25, 08:04	Sending IP used for Variant A wave 1
IP Address	198.18.44.23	Aug 25, 08:35	Sending IP used for Variant A wave 2
IP Address	198.18.51.7	Aug 25, 08:35	Sending IP used for Variant B
IP Address	198.18.7.200	Aug 25, 10:34:20	Attacker sign in IP from Amsterdam used to access Freya and Ryan
Domain	cloudora-hr-portal.example	Aug 25, 08:04	Main attacker-controlled lookalike domain
Subdomain	mail.cloudora-hr-portal.example	Aug 25, 08:04	Sending host used by Variant A

Subdomain	mailer.cloudora-hr-portal.example	Aug 25, 08:35	Sending host used by Variant B
Subdomain	login.cloudora-hr-portal.example	Aug 25, 09:05:44	Credential harvesting host used by Variant B
URL	hxxps://cloudora-hr-portal[.]example/payroll/login	Aug 25, 08:04	Variant A credential harvesting page
URL	hxxps://login.cloudora-hr-portal[.]example/verify	Aug 25, 09:05:44	Variant B credential harvesting page

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Initial Access	T1566.002	Phishing: Spear phishing Link	The attacker sent payroll themed phishing emails containing links to the fake Cloudora payroll portal.
Reconnaissance	T1598.003	Phishing for Information: Spear phishing Link	The phishing links led employees to a credential harvesting page where Freya Lynn and Ryan Boyd submitted their passwords. MITRE specifically includes malicious links that lead victims to credential phishing pages under this technique.
Initial Access	T1078.004	Valid Accounts: Cloud Accounts	The attacker used the stolen credentials to successfully sign into Freya Lynn and Ryan Boyd's Microsoft 365 accounts
Resource Development	T1583.001	Acquire Infrastructure: Domains	The attacker used the lookalike domain cloudora-hr-portal.example to support the phishing campaign. This is supporting infrastructure observed in the investigation.

6. Scope

Accounts confirmed compromised

freya.lynn@cloudora.io
ryan.boyd@cloudora.io

Both employees submitted credentials to the phishing site, and their accounts were later accessed from the attacker's IP 198.18.7.200.

Accounts targeted but not breached

Clicked but did not submit credentials:

seth.lane@cloudora.io
chloe.price@cloudora.io
hugo.marsh@cloudora.io
dina.said@cloudora.io

Received the phishing email but did not click:

adam.clark@cloudora.io, alba.vega@cloudora.io, amelia.frost@cloudora.io, aria.reid@cloudora.io, arjun.mehta@cloudora.io, cole.burke@cloudora.io, daniel.reeve@cloudora.io, dean.page@cloudora.io, ethan.wells@cloudora.io, felix.hart@cloudora.io, finn.gale@cloudora.io, gwen.muir@cloudora.io, isla.grant@cloudora.io, james.holt@cloudora.io, joel.kerr@cloudora.io, jude.ross@cloudora.io, kian.patel@cloudora.io, leah.stone@cloudora.io, lena.voss@cloudora.io, liam.doyle@cloudora.io, lucas.ford@cloudora.io, mira.shah@cloudora.io, noah.bishop@cloudora.io, olivia.kaur@cloudora.io, omar.farah@cloudora.io, priya.nair@cloudora.io, rhys.owen@cloudora.io, sofia.marino@cloudora.io, tara.kemp@cloudora.io, zara.aziz@cloudora.io.

Targeted but all quarantined:

emma.hayes@cloudora.io
maya.chen@cloudora.io
nina.cole@cloudora.io
ruth.dean@cloudora.io

7. Actions taken

Time (UTC)	Action	Performed by	Verified how
Aug 25, after 14:00	Revoked all active sessions and refresh tokens for Freya Lynn and Ryan Boyd	Eshak Basta	Checked both users in Microsoft Entra ID and confirmed their active sessions were revoked
Aug 25, after 14:00	Reset credentials for Freya Lynn and Ryan Boyd	Eshak Basta	Verified the password reset for both accounts in Microsoft Entra ID
Aug 25, after 14:00	Required and re registered MFA for both compromised accounts	Eshak Basta	Checked Microsoft Entra ID authentication methods and confirmed new MFA registration
Aug 25, after 14:00	Blocked 198.18.44.10, 198.18.44.23, 198.18.51.7, 198.18.7.200, cloudora-hr-portal.example and its subdomains	Eshak Basta	Verified the IPs and domains were present in the mail gateway and web proxy blocklists
Aug 25, after 14:00	Purged phishing emails from Cloudora mailboxes	Eshak Basta	Used Exchange Online Protection and message trace to verify the campaign messages were identified and removed
Aug 25, after containment	Verified the attacker no longer had access	Eshak Basta	Used KQL in Azure Data Explorer to rerun Freya and

			Ryan's sign in queries and pivot on 198.18.7.200. No attacker activity was found after containment
--	--	--	--

8. Recommendations

- Enforce MFA for all Cloudora accounts so a stolen password alone cannot be used to access an account. Both compromised accounts were accessed using stolen credentials.
- Reset the passwords for Seth Lane, Chloe Price, Hugo Marsh, and Dina Said as a precaution since they clicked the phishing link, even though they did not submit credentials.
- Change the `cloudora.io` DMARC policy to `p=reject` to help prevent attackers from successfully spoofing Cloudora email addresses like they did in Variant A.
- Add email security rules to detect newly registered lookalike domains and external emails claiming to come from `cloudora.io` that fail DMARC.
- Create a detection rule that alerts when an employee clicks a phishing link and then has a successful sign in from a new country shortly afterward. This could have detected both Freya and Ryan's compromises earlier.
- Permanently block the phishing IP addresses, domain, and subdomains identified during the investigation and monitor for similar lookalike Cloudora domains being created.
- Send phishing awareness communication to the employees who were targeted, reminding them that Cloudora will not ask them to enter their password or payroll information through links sent by email.

9. Lessons learned

The investigation showed how important employee reporting is because the first reported phishing email helped start the investigation. Message trace and KQL made it possible to find the full campaign and identify a second compromised account instead of stopping after finding the first victim. We also learned that passing SPF, DKIM, and DMARC does not always mean an email is safe because authentication can pass for an attacker-controlled lookalike domain. The biggest area for improvement is faster detection, since an alert connecting a phishing link click with a new country sign in could have detected both compromised accounts earlier.